

Cloud-Native User and Entity Behaviour Analytics for Insider-Threat Detection

Z.C Yap¹ and Firdaus Sahran^{1,2}

¹ Faculty of Computer Science and Information Technology, Universiti Malaya, 50603 Kuala Lumpur, Malaysia

² Centre of Research for Cyber Security and Network, Universiti Malaya, 50603 Kuala Lumpur, Malaysia

Abstract

Cloud adoption has dissolved the traditional network perimeter and amplified the risk of insider threats — abuse committed with legitimate credentials that signature-based defences are structurally blind to. This paper presents a cloud-native User and Entity Behaviour Analytics (UEBA) platform that detects insider activity, account compromise and data exfiltration without any labelled attack data. Heterogeneous activity logs from four cloud sources — AWS CloudTrail, Microsoft Azure AD sign-ins, Cloudflare Access and GitHub audit events — are normalised into a single eight-field schema. Per-user behavioural baselines are built from 71 engineered features capturing volume, timing, device, file and communication patterns, contextualised against K-Means behavioural peer groups. The final detector is a deep autoencoder trained only on normal user-days; its reconstruction error is the risk score, while an Isolation Forest, a rule scorer and a six-signal rarity scorer (including a geo-rarity flag derived from Cloudflare country data) are retained as interpretable baselines. Every alert is explained through SHAP feature attribution and a natural-language large-language-model assistant. On the CERT r4.2 benchmark (1,000 users, 70 insiders) the autoencoder attains AUROC 0.976, AUPRC 0.851 and F1 0.787 — within ~99% of a supervised stacking ensemble's AUROC (0.980) and ~90% of its F1, with zero labels — decisively outperforming the rule and isolation baselines. External validity is demonstrated on the flaws.cloud AWS dataset (AUROC 0.724) and a streaming live-replay (AUROC 0.917). The system is containerised and deployed on Docker, Hugging Face Spaces and Vercel. The results indicate that explainable, label-free insider detection is practical on free-tier infrastructure, with low-and-slow behaviour identified as the principal remaining challenge.

Keywords: UEBA · Insider threat detection · Unsupervised learning · Autoencoder · Explainable AI · SHAP · Cloud security · Log normalisation · Anomaly detection · Large language models.

1 Introduction

The migration of enterprise data and services to public cloud platforms such as Amazon Web Services (AWS) and Microsoft Azure has delivered scalability and accessibility, but it has also dissolved the network perimeter on which classical defences depend. Insider threats — attacks originating from users who already hold legitimate credentials and authorised access — are among the most damaging consequences of this shift.

According to the Verizon 2025 Data Breach Investigations Report, the human element is involved in roughly 60% of breaches, and stolen or misused credentials remain the dominant initial-access vector [1]. The Ponemon Institute estimates that organisations now spend an average of USD 17.4 million per year addressing insider-related risk, a 40% increase since 2019 [2]. Because insiders act within their granted privileges, signature- and rule-based tools such as intrusion-detection systems and SIEM platforms cannot reliably distinguish malicious from benign activity, and they generate excessive false positives when applied across diverse user populations without per-user context.

User and Entity Behaviour Analytics (UEBA) addresses these limitations by modelling each user's normal behaviour over time and flagging statistically significant deviations. However, prominent open-source UEBA and SIEM tools — Wazuh, OpenUBA and HELK — remain largely rule-based, operate on a single log source, and provide no explanation for why a user is flagged, leaving analysts with an opaque score and no actionable rationale.

This paper presents Argus, a cloud-native UEBA platform, and makes four contributions: (1) a normalisation layer that unifies four structurally distinct cloud log sources — AWS CloudTrail, Azure AD, Cloudflare Access and GitHub — into one eight-field schema; (2) a label-free detection pipeline whose final detector is a deep autoencoder, complemented by interpretable rarity signals; (3) per-alert explainability combining SHAP attribution with a large-language-model (LLM) analyst assistant; and (4) an evaluation that goes beyond the CERT benchmark to real cloud-breach data and a live streaming replay.

Four objectives guide the work: (i) to study the limitations of rule-based and open-source UEBA tools; (ii) to design a multi-cloud log-normalisation layer and behavioural-profiling pipeline; (iii) to develop a functional prototype combining autoencoder detection with SHAP per-alert explanations; and (iv) to evaluate the system on CERT r4.2 against rule-based baselines. The scope covers application-layer behavioural logs from the four cloud sources above; packet-level inspection and production-scale streaming are deferred to future work. Development followed an iterative design–build–evaluate cycle over a 14-week schedule. The remainder of this paper is organised as follows: Section 2 reviews related work, Section 3 presents the system design, Section 4 reports the evaluation, Section 5 discusses strengths and limitations, and Section 6 concludes.

2 Related Work

UEBA evolved from earlier User Behaviour Analytics systems, broadened to include non-human entities. Gartner formalised the category in 2015, recognising that monitoring only human activity left significant blind spots in organisational security posture [3].

2.1 Unsupervised Anomaly Detection

Datta et al. demonstrated real-time insider-threat detection with unsupervised learning on the CERT dataset, showing competitive detection without labelled attacks [4]. Liu et al. introduced Isolation Forest, which partitions the feature space at random and isolates anomalies in fewer splits, making it well suited to high-dimensional behavioural data [5]. Autoencoder approaches instead learn to reconstruct normal behaviour; inputs unseen during training yield elevated reconstruction error that serves directly as an anomaly score [6].

2.2 Explainable AI in Security

Lundberg and Lee proposed SHAP, a unified framework that explains model predictions using Shapley values from cooperative game theory [7]. Applied to intrusion detection, SHAP attributions have been shown to improve analyst trust by exposing each feature's contribution in an interpretable form [8]. The EU AI Act (2024) mandates explainability for high-risk AI systems in security-critical domains, further motivating the integration of explainable AI [9].

2.3 Limitations of Existing Tools

Wazuh encodes its detection logic as static XML rules with no adaptive learning [10]. OpenUBA offers basic statistical profiling but no per-user behavioural baselines, while HELK exposes Elasticsearch machine-learning primitives without a custom training pipeline or explanation layer. None of the evaluated tools normalise multiple cloud sources or provide per-alert explanations, which is precisely the gap this work addresses.

3 System Design and Methodology

Argus implements a decoupled, layered pipeline: log ingestion and normalisation, feature engineering and baseline construction, label-free detection, rarity signalling, explainability, and an analyst dashboard. Each layer communicates through a well-defined interface so that the detection and presentation layers remain entirely source-agnostic. The overall architecture and tool stack are shown in Fig. 1.

The design is driven by eight functional requirements — normalisation to a unified schema, per-user feature aggregation, peer-group assignment, autoencoder risk scoring,

SHAP explanation generation, a REST API, an analyst dashboard, and real-time ingestion — and six non-functional requirements covering accuracy ($\text{AUROC} \geq 0.90$), explainability (≥ 3 SHAP features per high-risk alert), extensibility (a new source requires only one parser), portability (single docker-compose deployment), performance, and input-validation security. Requirements were gathered through review of provider log-schema documentation, consultation with an industry collaborator (ECLOGIC Sdn Bhd), and analysis of the CERT attack scenarios.

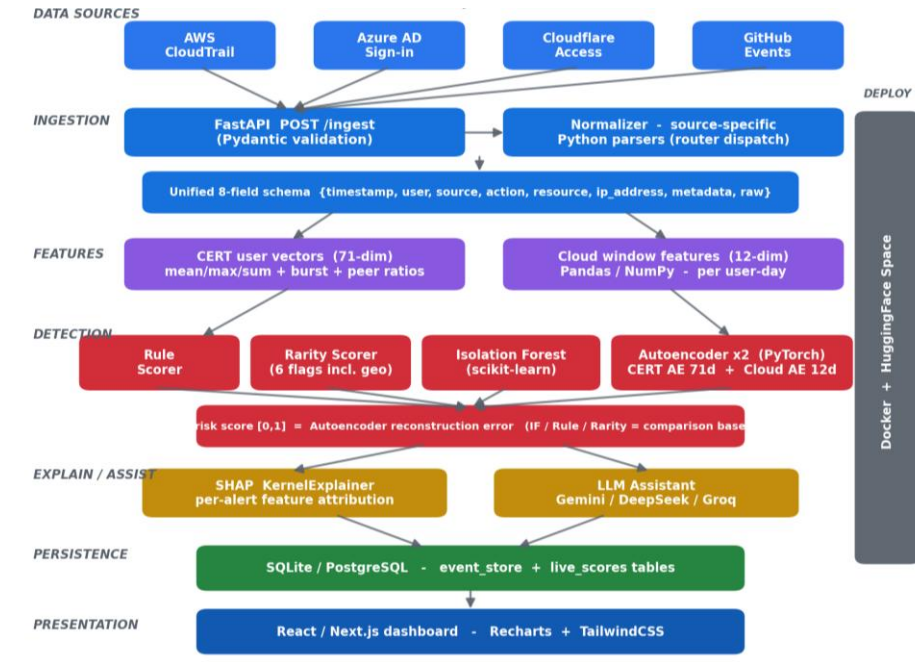


Fig. 1. Argus system architecture and tool stack: four cloud sources are normalized into one schema, scored by a label-free autoencoder with rarity and rule baselines, explained via SHAP and an LLM assistant, then surfaced on a web dashboard.

3.1 Multi-Cloud Log Normalization

Cloud providers emit structurally distinct logs. AWS CloudTrail records API calls in JSON (eventTime, userIdentity.userName, eventName, sourceIPAddress); Azure AD sign-in logs use createdAt, userPrincipalName and ipAddress; Cloudflare Access uses created_at, user_email, app_domain and a country field; GitHub audit events use their own actor and action keys. A normalisation layer maps all four onto a single eight-field internal schema: {timestamp, user, source, action, resource, ip_address, metadata, raw}, where metadata preserves source-specific fields (e.g. geo-location, Azure conditional-access status) and raw retains the unmodified original event.

This design keeps the downstream pipeline source-agnostic: adding a new provider requires only a single parser function, with no change to feature extraction, detection

or the dashboard. For the benchmark evaluation, the CERT r4.2 dataset is converted into the same schema, providing labelled ground truth across logon, file, email, device and HTTP activity [11].

3.2 Feature Engineering and Behavioural Baselines

Normalised events are aggregated into daily behavioural vectors per user. For CERT data, daily activity is aggregated into a 71-dimensional per-user vector — the mean, maximum and sum of 21 base behavioural features capturing volume, timing, device, file and communication patterns, augmented with burst ratios (peak-to-average activity spikes) and peer-group ratios; for live cloud data, a compact 12-dimensional per-user-day feature vector is used. K-Means clustering, fitted on normal users only, assigns each user to a behavioural peer group, and per-feature peer ratios quantify how far a user's behaviour departs from the norm of behaviourally similar users.

3.3 Label-Free Detection

Two unsupervised models are trained exclusively on normal user-days, with labelled malicious users excluded from training. An Isolation Forest (scikit-learn) isolates structurally distinct points in fewer partitioning steps, producing a normalised anomaly score in $[0, 1]$. A deep autoencoder (PyTorch) learns to reconstruct normal behavioural vectors; the mean-squared reconstruction error, normalised to $[0, 1]$, is the anomaly score for an input.

Unlike the earlier ensemble formulation, the autoencoder reconstruction error is used as the final risk score, because it gave the strongest separation in our experiments. The Isolation Forest, a threshold-based rule scorer, and a weighted average of Isolation Forest and autoencoder are retained as transparent baselines for comparison rather than as the production detector.

3.4 Rarity Signals

Complementing the autoencoder, a rarity scorer emits six interpretable binary flags per event: `first_time_action`, `new_ip`, `off_hours`, `high_volume`, `sensitive_resource` and `geo_rarity`. The `geo_rarity` flag fires when an event originates from a country never previously observed for that user, derived from the Cloudflare Access country field — the only source with reliable geolocation. The rarity score is the fraction of the six flags that fire, giving analysts a fast, human-readable corroboration of the model score.

3.5 Explainability

Every flagged event is passed to a SHAP KernelExplainer, which attributes the risk score to individual features and produces a ranked, human-readable reason string — for example, that after-hours activity and a first-seen IP address together account for the majority of an alert's score. A large-language-model assistant (configurable across

Gemini, DeepSeek and Groq) then converts this attribution into a concise natural-language narrative for the analyst, turning opaque scores into investigable intelligence and directly addressing the explainability mandate of the EU AI Act [9].

4 Evaluation

4.1 Dataset and Experimental Setup

The primary benchmark is the CERT Insider Threat Dataset r4.2 (Carnegie Mellon University), comprising roughly 32 million events from 1,000 simulated users over 17 months, of which 70 are designated malicious insiders [11]. The timeline is split chronologically: earlier activity (normal users only) trains the baselines and the autoencoder, while the held-out remainder, containing all 70 insiders, forms the test set. All experiments use a fixed random seed of 42 for reproducibility.

4.2 Detector Performance

Table 1 reports AUROC, AUPRC and F1 (at the F1-optimal threshold) for the four configurations on the CERT r4.2 test set. Because insiders are a small minority, AUPRC is reported alongside AUROC, as AUROC alone can overstate performance on imbalanced data. The autoencoder dominates every metric, and the corresponding ROC curves are shown in Fig. 2. To rule out transductive optimism, a five-fold inductive cross-validation — retraining the autoencoder on each training fold’s normal users and scoring held-out users only — yields AUROC 0.959 ± 0.004 , confirming that the headline result generalises to unseen users.

Table 1. Detector performance on CERT r4.2 (1,000 users, 70 insiders).

Model	AUROC	AUPRC	F1
Autoencoder (final)	0.976	0.851	0.787
Weighted average (IF + AE)	0.951	0.740	0.726
Isolation Forest	0.860	0.206	0.379
Rule-based	0.859	0.207	0.367

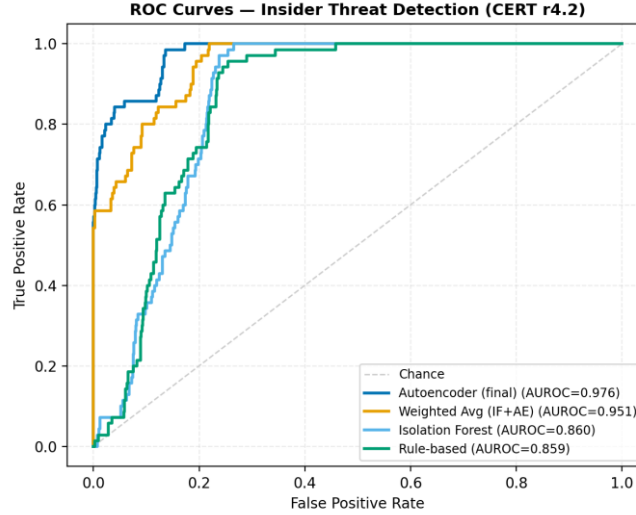


Fig. 2. ROC curves for the autoencoder and the rule and isolation baselines on CERT r4.2.

4.3 Real-World Validation

Benchmarks on simulated data can flatter a detector, so three external checks are performed. First, the cloud feature autoencoder is evaluated on the flaws.cloud AWS CloudTrail dataset, where it separates the Level-5/Level-6 attacker activity from benign API calls at AUROC 0.724 despite being trained without any attack labels. Second, a streaming live-replay drives events through the production /ingest endpoint and scores them online; the live pipeline attains AUROC 0.917 against an offline 0.976, confirming that the real-time path preserves most of the detector's accuracy. Third, a semi-synthetic evaluation on real GitHub activity — 240 genuine users with labelled attacker behaviour injected, following the same construction principle as CERT — yields AUROC 0.992, corroborating that the cloud pipeline separates planted attacks from authentic user behaviour.

4.4 Capability Comparison

Table 2 compares Argus with three widely used open-source UEBA/SIEM platforms across capabilities relevant to insider-threat detection in cloud environments. Argus is the only system to combine multi-cloud normalisation, label-free learning and per-alert explainability. Figure 3 shows the mean absolute SHAP attribution across the most influential features, illustrating which behaviours most often drive an alert.

Table 2. Capability comparison with open-source UEBA tools.

Capability	Wazuh	OpenUBA	HELK	Argus
Per-user baseline	No	Partial	No	Yes

Multi-cloud normalisation	No	No	No	Yes
Label-free ML detector	No	Partial	Limited	Yes
Rarity signalling	No	No	No	Yes
SHAP + LLM explainability	No	No	No	Yes
Academic + real-world eval	No	No	No	Yes

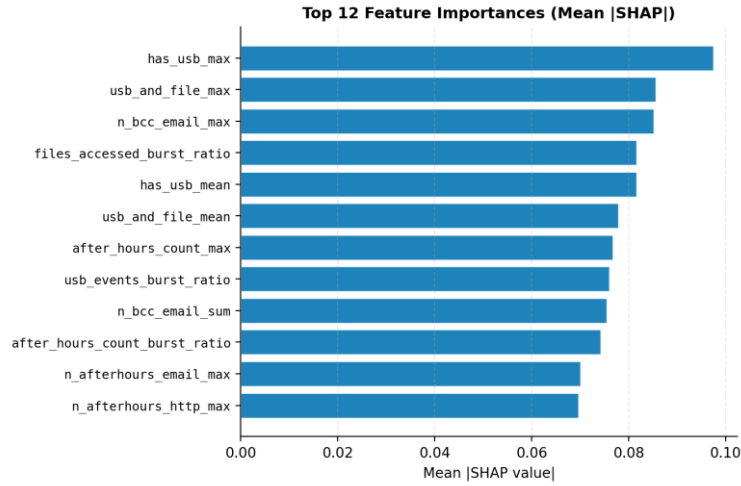


Fig. 3. Mean absolute SHAP attribution for the most influential behavioural features.

5 Discussion

5.1 Strengths

Training only on normal behaviour means Argus needs no labelled attacks, which are scarce and quickly stale in practice; yet it reaches roughly 99% of a supervised stacking ensemble's AUROC (0.980) and 90% of its F1. The rarity signals and SHAP attribution give analysts an immediate, human-readable rationale for each alert — a capability absent from every open-source tool evaluated — and the LLM assistant lowers cognitive load by narrating that rationale in plain language. The source-agnostic normalisation layer makes adding a new cloud provider a one-parser change. Fig. 4 shows the analyst-facing result: a risk-ranked dashboard with severity tiers and per-source badges.

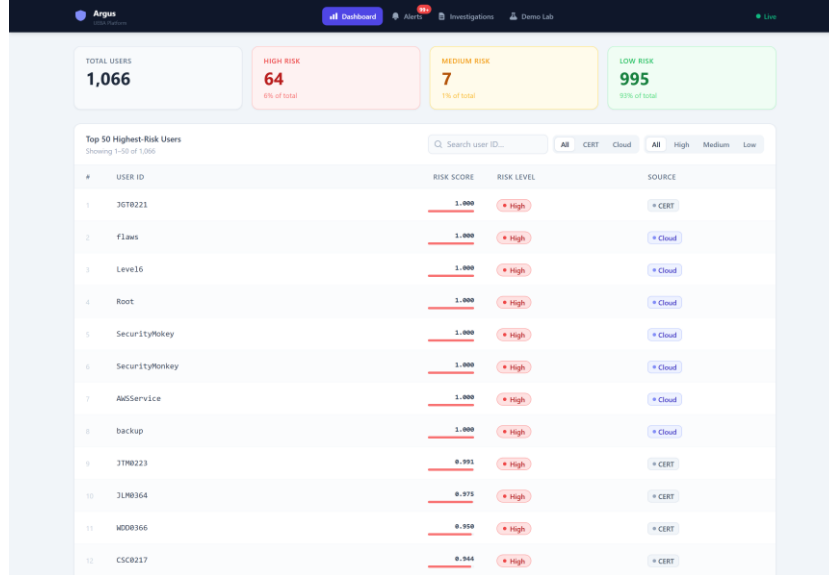


Fig. 4. The analyst dashboard: entities ranked by autoencoder risk score with severity tiers and per-source badges.

5.2 Limitations and Future Work

Several limitations remain. The CERT dataset, though the standard academic benchmark, is simulated; the flaws.cloud and live-replay results mitigate but do not fully remove this concern. Detection is also uneven across the three CERT insider scenarios: the autoencoder recovers the burst-like Scenario 1 (30/30) and Scenario 3 (10/10) but only the low-and-slow Scenario 2 (12/30), which a supervised stacking ensemble detects (27/30) — the signal is present in the features but missed by the per-day reconstruction objective. Because this is a temporal-representation gap rather than a model-capacity limitation, the planned remedy is a graded comparison of time-aware detection — change-point monitoring (CUSUM, consistent with the statistical-process-control basis of the baseline) and longitudinal trend features, evaluated against sequence models (LSTM / Transformer autoencoders) — to establish how much temporal modelling low-and-slow detection actually requires; an initial Transformer prototype did not yet improve Scenario 2, plausibly constrained by only 70 insider entities, so the contribution is the comparison itself. The primary detection-quality direction, however, is improving multi-cloud coverage through per-source feature engineering — for example incorporating Azure's native risk signals — since the cloud autoencoder was trained on AWS CloudTrail. The system does not yet detect model drift as legitimate behaviour evolves; future work will add KL-divergence drift detection with periodic retraining. A patient adversary could behave normally during baseline construction to poison it; adversarial-robustness evaluation is warranted. Finally, full streaming ingestion via a message bus such as Kafka is deferred as a scaling extension.

6 Conclusion

This paper presented Argus, a cloud-native UEBA platform that detects insider threats without labelled attack data. A four-source normalisation layer unifies AWS, Azure, Cloudflare and GitHub logs into one schema; a label-free autoencoder serves as the final detector, supported by interpretable rarity and rule baselines; and SHAP attribution with an LLM assistant explains every alert. On CERT r4.2 the autoencoder achieves AUROC 0.976, AUPRC 0.851 and F1 0.787, and external validation on flaws.cloud (AUROC 0.724) and a live streaming replay (AUROC 0.917) confirms its real-world viability. The work shows that effective, explainable, cloud-native insider-threat detection is achievable with open-source tools and custom unsupervised learning, without reliance on costly commercial platforms.

Acknowledgments. The author thanks Dr. Firdaus Sahran and the Faculty of Computer Science and Information Technology, Universiti Malaya, for their guidance and support; Mohd Akbar bin Abu Bakar (Lead Engineer, ECLOGIC Sdn Bhd) for industry collaboration validating the system's operational relevance; and Carnegie Mellon University for providing the CERT Insider Threat Dataset.

Disclosure of Interests. The authors declare that they have no competing interests.

7 References

1. Verizon: 2025 Data Breach Investigations Report. Verizon Enterprise Solutions (2025)
2. Ponemon Institute: 2025 Cost of Insider Risks Global Report. Proofpoint (2025)
3. Gartner: Market Guide for User and Entity Behavior Analytics. Gartner Research (2015)
4. Datta, J., Dasgupta, S., Dasgupta, R., Reddy, K.R.: Real-time threat detection in UEBA using unsupervised learning algorithms. In: Proc. IEEE IEMENTech (2021)
5. Liu, F.T., Ting, K.M., Zhou, Z.H.: Isolation forest. In: Proc. IEEE ICDM, pp. 413–422 (2008)
6. Inayat, U., Farzan, M., Mahmood, S., Zia, M.F., Hussain, S., Pallonetto, F.: Insider threat mitigation: a systematic literature review. *Ain Shams Engineering Journal* 15(12) (2024)
7. Lundberg, S.M., Lee, S.I.: A unified approach to interpreting model predictions. In: *Advances in Neural Information Processing Systems*, vol. 30 (2017)
8. Sharma, G., Thakur, A., Tiwari, C.: Developing a comprehensive framework for UEBA: integrating advanced ML and contextual insights. *Journal of Communication Engineering & Systems* (2024)
9. European Parliament: Regulation (EU) 2024/1689 — Artificial Intelligence Act. Official Journal of the European Union (2024)
10. Wazuh: The Open Source Security Platform. GitHub repository, <https://github.com/wazuh/wazuh>, last accessed 2025/05/30
11. Glasser, J., Lindauer, B.: Bridging the gap: a pragmatic approach to generating insider threat data. In: Proc. IEEE Security and Privacy Workshops (2013)